

PROCEDIMIENTO DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

1. Objetivo

Establecer los lineamientos y controles necesarios para garantizar la confidencialidad, integridad y disponibilidad de la información, así como la protección de los activos tecnológicos de la organización.

2. Alcance

Aplica a:

- Infraestructura tecnológica (servidores, red, UTM, equipos)
- Sistemas y aplicaciones
- Usuarios internos y externos
- Información en cualquier formato

3. Seguridad informática

Se implementan controles técnicos y administrativos para la protección de los activos de información, conforme al **Inventario de activos con controles**, donde se identifican los riesgos, amenazas y controles asociados.

Incluye:

- Seguridad perimetral (UTM, firewall)
- Seguridad en endpoints
- Segmentación de red
- Protección de la información

4. Políticas de seguridad

La gestión de seguridad se rige por la **Política corporativa de seguridad de la información**, la cual define los principios y lineamientos generales.

Adicionalmente, se consideran:

- Política de uso aceptable de la tecnología
- Política de continuidad operativa
- Política de respaldos

Todos los usuarios deben conocer y cumplir estas políticas.

5. Análisis de vulnerabilidades

Se realizan evaluaciones periódicas para identificar debilidades en la infraestructura tecnológica.

Este proceso se ejecuta en alineación con la **Metodología de análisis y gestión de riesgos**, considerando:

- Identificación de vulnerabilidades
- Evaluación de impacto y probabilidad
- Priorización de riesgos
- Planes de remediación

6. Gestión de UTM´s por Sitio

Se administran los dispositivos UTM de forma controlada, asegurando configuraciones seguras y homogéneas entre sitios.

Incluye:

- Definición de reglas de acceso
- Segmentación de red
- Control de tráfico
- Aplicación de políticas de seguridad

Las configuraciones deben estar alineadas con el **Inventario de activos con controles** y la **Política corporativa de seguridad de la información**.

7. Gestión de incidentes de seguridad

Se establece un proceso para la atención de incidentes de seguridad, considerando también la **Política de continuidad operativa**.

Flujo:

1. Detección
2. Registro
3. Análisis
4. Contención
5. Erradicación

6. Recuperación

7. Lecciones aprendidas

Los incidentes deben documentarse y analizarse para evitar recurrencia.

8. Gestión de accesos y políticas

El acceso a sistemas y recursos se controla con base en:

- Principio de mínimo privilegio
- Roles y perfiles
- Autenticación segura

Este control se realiza conforme a la **Política corporativa de seguridad de la información** y la **Política de uso aceptable de la tecnología**.

Incluye:

- Altas, bajas y cambios de usuarios
- Revisión periódica de accesos

9. RespalDOS y restauración (Instructivo)

La gestión de respaldos se realiza conforme a la **Política de respaldos**.

Lineamientos:

- Generación periódica de respaldos
- Almacenamiento seguro
- Pruebas de restauración
- Control de versiones

Esto asegura la recuperación de la información ante incidentes.

10. Monitoreo y auditoría

Se realiza monitoreo continuo de la infraestructura y revisión de eventos de seguridad.

Incluye:

- Revisión de logs
- Generación de alertas

- Auditorías internas

Estas actividades se alinean con el **Inventario de activos con controles** y la **Metodología de análisis y gestión de riesgos**.

11. Gestión de actualizaciones de firmware

Se controla la actualización de dispositivos tecnológicos para mitigar vulnerabilidades.

Proceso:

- Evaluación de actualizaciones
- Programación de instalación
- Validación posterior
- Registro de cambios

En alineación con la **Metodología de análisis y gestión de riesgos**.

12. Campañas de concientización

Se realizan acciones de capacitación para fortalecer la cultura de seguridad.

Incluye:

- Buenas prácticas
- Prevención de phishing
- Uso seguro de contraseñas
- Manejo de información

En concordancia con la **Política de uso aceptable de la tecnología**.

13. Gestión de antivirus (Instructivo)

Se implementan controles de protección en endpoints.

Lineamientos:

- Instalación obligatoria
- Actualización automática
- Escaneos periódicos
- Monitoreo de estado

Alineado con la **Política corporativa de seguridad de la información**.

14. Marco normativo y documentos relacionados

El presente procedimiento se integra con los siguientes documentos internos:

- Inventario de activos con controles
- Metodología de análisis y gestión de riesgos
- Política corporativa de seguridad de la información
- Política de continuidad operativa
- Política de respaldos
- Política de uso aceptable de la tecnología

Estos documentos establecen las bases para la identificación, protección, gestión y recuperación de los activos de información, y son de cumplimiento obligatorio.

Asimismo, se adoptan buenas prácticas basadas en:

- ISO/IEC 27001
- ISO/IEC 27002

como marco de referencia para la gestión de seguridad de la información.

15. Responsabilidades

- **Área de TI:** Implementación, monitoreo y control del procedimiento
- **Usuarios:** Cumplimiento de políticas y buenas prácticas